MAS

FINANCIAL RESILIENCE SCOPING ENGINE

Strategic Nexus

MAS TRM Pack

Threat-Led Penetration Testing Scoping Document — Nexus v33.0

ENTITY	RESILIENCE INDEX	ENGAGEMENT DURATION	CLASSIFICATION
MAS TRM Pack	100%	70 Days	Restricted

Financial Resilience Coverage Index

10

TLPT RESILIENCE INDEX

Financial Resilience Coverage Score

This score reflects the breadth of coverage across the four mandatory Threat-Led Penetration Testing pillars required under DORA Article 26, PRA CBEST, and HKMA iCAST.

TLPT COMPLIANCE PILLAR	COVERAGE STATUS
Threat Intelligence Profiling	VALIDATED
Covert Attack Emulation	VALIDATED
Purple Team Collaboration	VALIDATED
Executive Crisis Validation	VALIDATED

Executive Resourcing & Schedule Summary

The following summarizes the operational timeline and resourcing required to execute the defined Threat-Led Penetration Testing modules in alignment with regulatory mandates.

70
TOTAL ENGAGEMENT DAYS

14
EXECUTION WEEKS

4
TLPT PERSONNEL

4
ACTIVE MODULES

Automated TLPT Resourcing Allocation

ROLE	HEADCOUNT	TLPT RESPONSIBILITY	CLEARANCE
Threat Intel & Red Team Lead	1	Strategic oversight, regulatory coordination, TI report authorship, and final QA gate review.	Full Knowledge
Covert Red Team Operator	3	Technical execution, assumed breach operations, exploit development, and stealth persistence.	Full Knowledge
Purple Team Facilitator	1	Replay exercise facilitation, SOC detection tuning, and SIEM rule validation.	Full Knowledge
Client White Team	TBD	Kill-switch authority, CBS owner coordination, and regulatory notification.	Full Knowledge

1.5 Regulatory Alignment: MAS TRM Pack

Narrative: Singapore MAS TRM compliance pack for VAPT and Red Team exercises.

REGULATORY BODY

Monetary Authority of Singapore (MAS) TRM (Singapore)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
TRM Section 9	Cyber Risk Management	Institutions must establish a robust cyber risk management framework with Board-level oversight.	Board-level reporting on cyber risk and TLPT results mandatory.
TRM Section 12	Vulnerability Assessment and Penetration Testing (VAPT)	Conduct comprehensive VAPT on all critical IT systems annually or upon major system changes.	All internet-facing applications, core banking platforms, and payment APIs.
TRM Section 13	Cyber Incident Response & Management	Simulate adversary attacks to test the detection, containment, and recovery capabilities of the institution.	Red team exercises for major institutions. Incident response plan must be tested at least annually.
Notice MAS 655	Cyber Hygiene Baseline	Mandatory baseline cyber hygiene measures including network segmentation, patching, MFA, and logging.	Technical controls audit and validation as part of Red Team execution scope.

Mandatory Evidence Artifacts:

- VAPT Report
- Red Team Execution Log
- Root Cause Analysis Report
- Remediation Status Register
- Board Cyber Risk Report

MAS Notice MAS 655 Baseline Cyber Hygiene Controls

MAS Notice MAS 655, effective 6 August 2020, mandates baseline cyber hygiene measures for all MAS-regulated financial institutions. These include: (1) network segmentation, (2) timely software patching, (3) multi-factor authentication on privileged and internet-facing systems, (4) malware protection, and (5) activity logging. VAPT scope must validate the effective implementation of all MAS 655 baseline controls.

TRM Section 12 — Vulnerability Assessment & Penetration Testing

MAS TRM Section 12 requires comprehensive VAPT on all critical IT systems, to be conducted at least annually or upon any major system change. VAPT must be conducted by qualified independent assessors. Results, including identified vulnerabilities and remediation actions, must be reported to senior management. Systems deemed critical under MAS definitions must be retested to verify remediation effectiveness.

Red Team Exercise Frequency & Scope

MAS TRM Section 13 requires major financial institutions to conduct Red Team exercises to test their detection, containment, and recovery capabilities. For institutions designated as major or systemically important, Red Team exercises should be conducted at least every 2 years. The scope must encompass internet-facing systems, core banking platforms, payment APIs, and data centres. Findings must be reviewed by the Board Risk Committee.

PDPA Compliance & Data Handling

All assessment data, execution logs, and findings reports must be handled in full compliance with Singapore's Personal Data Protection Act (PDPA). Any personal data of bank customers that is encountered during testing must be immediately reported to the White Team and excluded from further analysis. The engagement must include a formal Data Handling Protocol as an annex to this Scoping Document.

MAS Technology Risk Notification Obligations

Under MAS Notice MAS 644, institutions must notify MAS of any significant technology risk incidents within 1 hour of discovery and provide a root cause report within 14 days. Any critical vulnerability discovered during the TLPT engagement that poses an immediate systemic risk must be treated as a notifiable incident. The Red Team Lead must have a direct communication channel to the White Team for immediate escalation.

Framework Specific Guidance

MAS Implementation Guidance

MAS Notice MAS 655 Baseline Cyber Hygiene Controls

MAS Notice MAS 655, effective 6 August 2020, mandates baseline cyber hygiene measures for all MAS-regulated financial institutions. These include: (1) network segmentation, (2) timely software patching, (3) multi-factor authentication on privileged and internet-facing systems, (4) malware protection, and (5) activity logging. VAPT scope must validate the effective implementation of all MAS 655 baseline controls.

TRM Section 12 — Vulnerability Assessment & Penetration Testing

MAS TRM Section 12 requires comprehensive VAPT on all critical IT systems, to be conducted at least annually or upon any major system change. VAPT must be conducted by qualified independent assessors. Results, including identified vulnerabilities and remediation actions, must be reported to senior management. Systems deemed critical under MAS definitions must be retested to verify remediation effectiveness.

Red Team Exercise Frequency & Scope

MAS TRM Section 13 requires major financial institutions to conduct Red Team exercises to test their detection, containment, and recovery capabilities. For institutions designated as major or systemically important, Red Team exercises should be conducted at least every 2 years. The scope must encompass internet-facing systems, core banking platforms, payment APIs, and data centres. Findings must be reviewed by the Board Risk Committee.

PDPA Compliance & Data Handling

All assessment data, execution logs, and findings reports must be handled in full compliance with Singapore's Personal Data Protection Act (PDPA). Any personal data of bank customers that is encountered during testing must be immediately reported to the White Team and excluded from further analysis. The engagement must include a formal Data Handling Protocol as an annex to this Scoping Document.

MAS Technology Risk Notification Obligations

Under MAS Notice MAS 644, institutions must notify MAS of any significant technology risk incidents within 1 hour of discovery and provide a root cause report within 14 days. Any critical vulnerability discovered during the TLPT engagement that poses an immediate systemic risk must be treated as a notifiable incident. The Red Team Lead must have a direct communication channel to the White Team for immediate escalation.

Threat Scenarios & Modeling

Threat Intelligence Profiles

MANDATORY REQUIREMENT PENDING: A Threat Intelligence phase or report must be completed and formally appended to define the attack scenarios before Red Team or Intelligence-Led testing begins.

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Payload & Exploit Transmission	Zero-Knowledge End-to-End Encryption (E2EE)
Exfiltrated Data Storage	Ephemeral Air-Gapped Analysis Environment (256-bit AES)
Red Team Telemetry Retention	Secure SOC Aggregation (Strict 30-Day Limit)
Artifact Destruction	NIST 800-88 Compliant Cryptographic Wipe

2.2 Data Sovereignty & Residency

To adhere to regulatory data protection requirements, the following residency rules apply to all engagement artifacts.

FRAMEWORK	RESIDENCY MANDATE
MAS	Financial data and all assessment details must comply with the Singapore PDPA and MAS Outsourcing Guidelines. On-shore processing is strongly preferred; offshore processing requires MAS notification.

2.3 Regulator Audit & Access Rights

The following audit rights and access privileges are contractually granted to the respective regulatory bodies.

REGULATOR	ACCESS RIGHTS
MAS	MAS requires immediate notification of any critical vulnerabilities and retains the right to independently audit all VAPT reports, Red Team logs, and remediation evidence.

Operational Team Governance

PART II.A: TEAM STRUCTURE

STRICTLY CONFIDENTIAL // STRATEGIC SCOPE

White Team & Control Group Structure

In accordance with intelligence-led frameworks (CBEST/iCAST), the engagement must be overseen by a strictly segregated Control Group to ensure operational safety without alerting the defensive Blue Team.

GOVERNANCE BODY	REGULATORY RESPONSIBILITY	CLEARANCE LEVEL
The White Team	Engagement sponsors holding the emergency Kill-Switch. Responsible for defining the Critical Business Services (CBS) and Impact Tolerances.	Full Knowledge
The Control Group	A trusted subset of the client's internal IT/Security team who monitor the engagement for safety but do not participate in defense.	Full Knowledge
The Blue Team	The operational SOC and incident responders who must defend the network as if under a real attack.	Zero Knowledge
Threat Intel Provider	Independent vendor supplying the threat landscape profiles and attack scenarios to the Red Team.	Execution Phase
Covert Red Team	The execution unit simulating the Threat Actor's TTPs against the CBS.	Execution Phase

Critical Business Services & Impact Tolerance

PART II.C: CBS IMPACT TOLERANCE

Critical Business Services (CBS) Scope

⚠ **ACTION REQUIRED — CBS DECLARATION MISSING:** No Critical Business Services have been declared. Under DORA Article 26 and PRA CBEST, the client must map target infrastructure to its underlying business function and formally define the maximum impact tolerance before testing may begin.

Access & Test Data Readiness

> Standard testing prerequisites apply: Client must provide stable network access (VPN/Jump host), valid application credentials (min. 2 per role), and any required API documentation prior to the start of the testing window.

Third-Party ICT Supply Chain Scope

PART II.D: THIRD-PARTY RISK

Third-Party ICT Dependency Register

> No third-party ICT dependencies or hosted environments have been declared in scope. Testing is restricted to first-party infrastructure.

Technical Scope of Work

TI-PHASE — **Targeted Threat Intelligence Gathering**

Formally scoped intelligence gathering phase designed to identify threat actors, define attack scenarios, and produce the Threat Intelligence Profile required before Red Team execution.

Allocated Schedule: 15 Days

RT-COVERT — **Covert Red Team Execution**

Intelligence-led, objective-based penetration testing executing the scenarios defined in the TI-PHASE. Includes stealth, evasion, and assumed-breach scenarios against core financial systems.

Allocated Schedule: 40 Days

PT-REPLAY — **Purple Team Replay Exercises**

Collaborative replay of Red Team attack chains alongside the defensive Blue Team to validate SOC detections, incident response capabilities, and SIEM rule effectiveness.

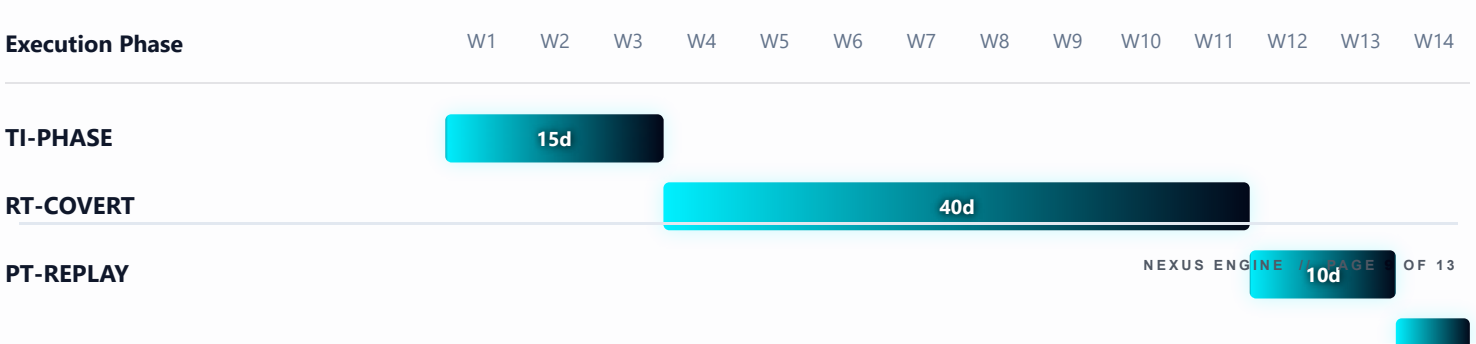
Allocated Schedule: 10 Days

IR-VALIDATION — **Incident Response & Crisis Validation**

Executive tabletop and crisis management simulation based on the findings from the Red Team execution to validate Board-level incident response maturity.

Allocated Schedule: 5 Days

Execution Timeline (Gantt)



Financial Control Mapping (Omni Matrix)

PART III.B: OMNI MATRIX

Financial Control Mapping (Omni Matrix)

The following TLPT-specific financial controls are in scope for the selected execution modules, mapped to their regulatory article references.

CONTROL ID	CONTROL NAME	FRAMEWORK	REGULATORY REFERENCE	IMPACT RATING
CB_01	Core Banking Network Segmentation	DORA	Art. 24 (TLPT)	**Critical**
CB_02	Retail Payment Infrastructure Isolation	DORA	Art. 26 (ICT Resilience)	**Critical**
SW_01	SWIFT Gateway Network Isolation	PRA CBEST	Objective A – Segregation	**Critical**
SW_02	SWIFT Messaging Integrity Validation	PRA CBEST	Objective B – Data Integrity	**Critical**
IAM_01	Privileged Access Management (PAM)	FRB	SR 13-1 – Access Control	**High**
IAM_02	Service Account Credential Hygiene	MAS TRM	Section 12.3 – IAM	**High**
IAM_03	Multi-Factor Authentication Enforcement	MAS TRM	Section 12.4 – Authentication	**High**
TI_01	Threat Intelligence Profile Development	HKMA iCAST	CFI 2.0 – TI Framework	**High**
TI_02	Threat Actor Attribution & Profiling	PRA CBEST	CBEST TI Module	**High**
TI_03	Attack Scenario Development (MITRE ATT&CK)	HKMA iCAST	CFI 2.0 – Scenario Modelling	**High**
TI_04	Threat-Led Defense Posture Assessment	HKMA iCAST	CFI-2 – Posture Review	**High**
IR_01	Active Incident Response Capabilities	DORA	Art. 26 – Crisis Management	**Medium**
IR_02	Executive Crisis Management Simulation	PRA CBEST	CBEST – Closure Report	**Critical**
IR_03	SOC Detection & SIEM Validation	MAS TRM	Section 13 – Incident Response	**High**
IR_04	Purple Team Replay & Remediation Verification	FRB	SR 11-7 – Model Validation	**Medium**
DR_01	Disaster Recovery Plan Validation	DORA	Art. 11 – Business Continuity	**Critical**
DR_02	RTO / RPO Objective Testing Under Load	FRB	SR 13-1 – Continuity	**High**
API_01	Open Banking API Security Boundary	MAS TRM	Section 12.1 – API Controls	**High**
CLD_01	Cloud Workload Lateral Movement Detection	DORA	Art. 30 – ICT Third-Party Risk	**High**

RACI Responsibility Assignment Matrix

Defines who is Responsible, Accountable, Consulted, and Informed for each TLPT activity across all parties.

ACTIVITY	THREAT INTEL PROVIDER	COVERT RED TEAM LEAD	CLIENT WHITE TEAM	CLIENT CONTROL GROUP	CLIENT SECURITY OPS (SOC)	CLIENT EXEC SPONSOR / CISO
Targeted Threat Intelligence Gathering	R	C	A	I	I	I
Attack Scenario & TTP Development	R	C	A	I	I	I
Critical Business Service (CBS) Declaration	I	I	A	C	C	R
Regulator & Scope Notification	I	C	A	I	I	R
White Team Briefing & Kill-Switch Assignment	I	C	R	C	I	A
Covert Red Team Execution (TLPT)	C	R	A	I	I	I
Emergency Kill-Switch Activation	I	C	R	C	I	A
Purple Team Replay Exercises	C	R	I	I	A	I
SOC Detection Rate Validation	I	C	A	C	R	I
Executive Crisis Management Tabletop	I	C	A	I	I	R
Remediation Planning & Sign-off	I	C	C	I	R	A
Regulator Artifact Submission	C	C	I	I	R	A

Regulatory Deliverables Schedule

Regulatory Deliverables Schedule

The following reports and evidence logs are contractually required to satisfy the loaded regulatory frameworks.

REGULATORY BODY	MANDATORY DELIVERABLE ARTIFACT
Monetary Authority of Singapore (MAS) TRM	VAPT Report
Monetary Authority of Singapore (MAS) TRM	Red Team Execution Log
Monetary Authority of Singapore (MAS) TRM	Root Cause Analysis Report
Monetary Authority of Singapore (MAS) TRM	Remediation Status Register
Monetary Authority of Singapore (MAS) TRM	Board Cyber Risk Report

Quality Assurance & Peer Review

PART IV.B: QUALITY ASSURANCE

Formal Quality Assurance Gate

Based on the selected regulatory frameworks and execution modules, the following QA routing is algorithmically enforced.

REQUIRED QA LEVEL: TLPT Qualified Red Team Reviewer

Mandatory Threat-Led Penetration Testing (TLPT) review gate. Evidence and kill-chain paths must be validated by a certified Red Team peer reviewer before report release.

Verification & Sign-off

PART V: AUTHORIZATION

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

Engagement Sign Off & Authorization

By signing below, the parties confirm that this Nexus Scoping Document has been reviewed and is accepted as the binding scope of work for the defined Threat-Led Penetration Testing engagement. This document satisfies the engagement scoping requirements for the active regulatory frameworks: **DORA, PRA CBEST, HKMA iCAST, FRB, and MAS TRM**.

SIGNATORY ROLE	FULL NAME	SIGNATURE	DATE
Client Executive Sponsor / CISO			
Client White Team Lead			
Red Team Lead (Provider)			
Threat Intelligence Lead (Provider)			

✓ **Document Control:** This document is classified **RESTRICTED**. Distribution is limited to parties named in the White Team register. Regulatory bodies retain audit rights as defined in Part II of this document.